



Carta de Riscos de Segurança da Informação

Avaliação da Evertec Dupie – Plataforma de Duplicatas Escrituradas

Data: 11 de junho de 2026

Origem: Segurança da Informação – BS2

Assunto: Parecer Executivo de Riscos – Modelo Arquitetural SaaS Multi-tenant

1. Contexto Executivo

Esta carta apresenta a avaliação executiva dos riscos associados ao uso da solução Evertec Dupie, classificada como SaaS cloud-native e operando sob modelo multi-tenant, utilizada para escrituração, registro e gestão de duplicatas escriturais.

A solução manipula dados financeiros e dados pessoais (CPF/CNPJ e dados transacionais), sendo considerada crítica no contexto regulatório e operacional do banco.

Embora a plataforma apresente controles relevantes de segurança (criptografia, autenticação via OAuth2/OIDC, logs e monitoramento), a arquitetura multi-tenant introduz riscos estruturais relacionados à segregação lógica de dados e dependência do fornecedor.

2. Principais Riscos Identificados

A análise técnica identificou riscos que impactam principalmente Confidencialidade, Integridade, Governança e risco operacional, conforme detalhado abaixo.

2.1. Confidencialidade

- O modelo multi-tenant implica compartilhamento de infraestrutura e componentes entre diferentes clientes.
- Existe risco potencial de falhas na segregação lógica de dados entre tenants, podendo resultar em exposição cruzada.
- A necessidade explícita de comprovação técnica de isolamento indica que o risco depende fortemente da implementação do fornecedor.



2.2. Integridade

- A dependência de mecanismos de controle lógico (RBAC, claims e segregação por tenant) pode gerar inconsistências entre permissões e regras de negócio, caso não sejam rigorosamente governadas.
- Integrações com múltiplos sistemas e terceiros aumentam a superfície de ataque e a complexidade de controle de dados.

2.3. Disponibilidade

- A solução possui dependência operacional de terceiros regulados (registradoras), o que pode impactar a continuidade do serviço.
- O uso de modelo SaaS implica dependência da disponibilidade do fornecedor e da infraestrutura compartilhada.

2.4. Risco Operacional e Arquitetural

- Forte dependência do fornecedor para processos críticos de negócio, reduzindo o controle direto pelo banco.
- O modelo multi-tenant traz risco estrutural associado a ambientes compartilhados.
- Possível dificuldade de auditoria independente e validação contínua dos controles internos do provedor.
- A ocorrência do incidente da Sinquia (<https://g1.globo.com/economia/noticia/2025/09/02/ataque-hacker-sinquia.ghml>), o ataque hacker desviou R\$ 710 milhões, evidencia o risco concreto associado à exposição de credenciais privilegiadas, reforçando a criticidade da gestão segura de acessos em ambientes compartilhados.
- No modelo atual, a gestão de credenciais e acessos privilegiados encontra-se sob responsabilidade do fornecedor, não estando integralmente sob a governança do BS2, o que amplia o risco de uso indevido, vazamento ou comprometimento dessas credenciais críticas.
- Observa-se a ausência de certificações formais de segurança da informação por parte do fornecedor, reduzindo o nível de confiança quanto à maturidade dos controles implementados e à aderência a padrões consolidados de mercado.

3. Conclusão

A solução foi classificada como “Aprovada com ressalvas”, com destaque para riscos relacionados à governança, segregação de dados e dependência do fornecedor.

Ainda que existam controles de segurança implementados (criptografia, autenticação forte, logs e testes recorrentes), os riscos não são eliminados, pois são inerentes ao modelo arquitetural adotado.

O ponto mais relevante é que o modelo SaaS multi-tenant representa um risco estrutural, exigindo validações contínuas e evidências técnicas de isolamento, o que aumenta a complexidade de gestão e auditoria.

4. Recomendação Formal

Considerando os riscos identificados, recomenda-se:

- Avaliar e priorizar a adoção de modelo **SaaS single-tenant**, eliminando riscos de compartilhamento de ambiente e reduzindo a exposição a falhas de segregação lógica.
- Garantir que o ambiente seja **dedicado ao banco**, com isolamento completo de dados, processamento e identidade.
- Reduzir a dependência de controles lógicos de segregação, substituindo-os por isolamento físico ou fortemente segregado por arquitetura dedicada.
- Manter as demais recomendações dos pareceres de Segurança da Informação e Arquitetura Tech, incluindo:
 1. Governança de acessos (RBAC e MFA)
 2. Integração com SIEM
 3. Garantia de evidências de segurança e auditoria
 4. Execução contínua de testes de segurança

Adicionalmente, reforça-se que a evolução para modelos mais controláveis (como single-tenant ou híbrido) é uma diretriz estratégica para redução de risco no médio e longo prazo.